

격리 누출이 실제로 0이 되었습니다 (파일럿)

12스프린트 동안 못 달던 테넌트 격리를, 파일럿 라우트에서 **실측 누출 0건**으로 달았습니다. 저하 운전도 완료. 남은 것은 확대와 API 계약뿐입니다. 판정 4건을 확정합니다.

15→0

man(Anyang) 누출 건수
착수 15 → 지금 0

15→0

son(레거시) 누출
플래그 한 줄로 차단

500→200

스트리밍 다운 시 목록 API
저하 운전 완료

파일럿 실측 — 누출 감소

복제본·같은 엔드포인트·같은 방법으로 3회 측정. 데코레이터 부착률이 아니라 실제 재현 누출 건수입니다(D-249 기준).

계정	착수 → W0-16 후 → 지금				지금
man Anyang · 역할 회수완료	15		1		0
	착수		W0-16		지금
son 레거시 역할 보유	—		15		0
	착수		W0-16		플래그
admin Gaion · 전역 역할	18		18		누출 아님
	착수		유지		정의

admin은 전역(GAION 운영자) 역할이므로 18건 조회가 정의상 정상 — 누출이 아니라 설계된 권한. man·son의 교차 노출만 결함이었고, 둘 다 0.

★ 가장 큰 발견 — 13계정 즉시 회수는 필요 없다

역할을 회수하지 않아도 `TENANT_TRUST_LEGACY_SUPERUSER=False` 한 줄로 son 누출이 15→0. 즉 격리 차단은 플래그가 먼저 하고, 13계정 역할 회수는 위험한 선행조건이 아니라 뒤따르는 정리 작업이 됩니다. D-243에서 걱정하던 "업무 무중단"이 대부분 해소됩니다.

W0-17 저하 운전 done

스트리밍 서버 죽인 상태 → 목록 API
500→200(stream_status:"unavailable"), 이력·통계·드론목록
200 유지. pre-commit 혹 + 단위시험 11건 회귀 게이트.

작성자 오류 #18

지시서 "timeout 없는 49건"은 과대추정 — AST 실측 17건(나머지는 redis·OpenSearch·테스트클라·dict). 실측대로 17→0 처리. (D-214 기록)

판정 4건 — 전부 승인

Code가 근거를 갖춰 적재한 판정 요청입니다. 전부 권고안대로 승인합니다.

D-252 격리 즉시 통제 = 플래그 우선 (중대 발견)

승인

격리 1차 통제는 TENANT_TRUST_LEGACY_SUPERUSER=False 플래그로 한다 — 즉시·가역·업무 무중단. 13계정 역할 회수(W0-16)는 뒤따르는 정리 작업으로 재순위. 단, 운영 플래그 전환은 W0-13 백필 완료 후(orphan 손실 방지).

D-253 격리 시험 "배선"만 수정 (P-W0-14-2, A안)

승인

EXIT "시나리오 5/5"가 판정 전에 죽음(404 4건·401 1건·필수 FK 24건). 배선·픽스처(실경로·메서드·필수필드)만 수정 승인, 격리 단언은 무변경(D-105 준수). 판정 가능 상태로 만든다.

D-254 652 확대 전 W0-13 백필 선행 (P-W0-14-3)

승인

스코프 적용 시 group 빈 13건(33%)이 화면에서 사라짐(orphan 손실). created_by/group 백필을 확대 전에. 파괴적이므로 dry-run 리포트 먼저(D-209) → 대표 확인 후 적용.

D-255 외부 의존 저하운전 분리 (P-W0-17-1)

승인

Redis-OpenSearch-MinIO 저하운전을 신규 티켓 W0-19(P1)로 분리. W0-17(스트리밍)은 done 유지. W0-19는 WP-2 EXIT 후 착수.

주목 — 네 건 모두 Code가 "손대면 안 되는 것(격리 단언·\$0.4)"과 "손대도 되는 것(배선·플래그)"을 정확히 구분해 올렸습니다. D-105·D-250 선례를 스스로 지키며 판정만 요청한 것 — 검토개발이 자리를 잡았다는 신호입니다.

다음 실행 순서 · EXIT

Code 질문("W0-18 먼저? 판정 먼저?") 답: 판정은 여기서 다 했으니, 격리 체인을 EXIT 판정 가능 상태까지 달은 뒤 W0-18. 한 WP-2 안에서 연속 진행.

- 1 **W0-14b** 격리 시험 배선 수정 (D-253) — 5개 시나리오가 죽지 않고 판정까지 도달. 단언 무변경.
- 2 **W0-13** created_by/group 백필 (D-254) — dry-run 먼저 → 대표 확인 후 적용. orphan 33% 해소.
- 3 **W0-14c** 652 라우트 확대 — 파일럿 방식을 전 라우트에. 목표: 전 계정 누출 0건, 시나리오 5/5.
- 4 **W0-18** API 계약 (D-248) — 후처리 계층 200-body-403 → 403(\$0.4 무수정) + 하위호환 + 엔드포인트 문서 정정 + 계약 테스트.
- 5 **W0-19** 외부 의존 저하운전(P1) — WP-2 EXIT 후 별도. 지금 착수 금지.

✓ WP-2 EXIT (누출 0건 기준) — 넷 다 충족 시 한 번에 제출

1. 재현 누출 0건(전 계정) · 격리 시나리오 5/5 (배선 수정 후 판정 가능)
2. 플래그/대체역할 무중단 검증 + superuser 회수 절차서 (운영 반영은 대표 승인 대기)
3. 스트리밍 다운 시 핵심 200 유지 — **done (W0-17)**
4. 응답 후처리 계층 + 하위호환 계획 + 계약 테스트 green + 연동 문서 갱신 (W0-18)
5. 시크릿 0건 · \$0.4 무변경 · 파괴적 변경 dry-run 첨부

⚡ **긴급 병행 (대표/운영자, 착수와 무관·지금):** 자격증명 회전 + 운영서버 9200·5601 포함 IP 제한(D-251). **좋은 소식:** D-252로 13계정 즉시 회수는 불필요 — 플래그가 먼저 달립니다. 회수는 뒤에 여유 있게 하시면 됩니다.

이 지시서 붙여넣기 = 판정 4건 확정 + 계속 진행 승인. WP-2 진행 중이므로 별도 ENTRY 재승인은 필요 없습니다. 다음 보고는 652 확대 후 전 계정 누출 0건 · 시나리오 5/5 실측이 될 것입니다 — 그것이 WP-2 EXIT의 핵심 증거이자 다음 지자체 계약의 열쇠입니다.